

Information Security Policy

Code SEC-001 — Version 7 — Approved January 15, 2026 — Owner: Marcos Ettinger (CISO)

1. Purpose and scope

This policy establishes the mandatory security controls for all staff, contractors, and vendors of Nimbus Data Systems. It applies to all systems, data, and devices used for work purposes. The company has held SOC 2 Type II certification since 2023, renewed annually, and is in the process of obtaining ISO 27001 certification, with the audit scheduled for September 2026.

2. Information classification

All information is classified into four levels. The level determines the applicable storage, transmission, and access controls:

Level	Description	Examples
Public	Can be disclosed without risk	Website, marketing material
Internal	Company staff only	Process documentation, wikis
Confidential	Access restricted by role	Customer data, source code, contracts
Restricted	Named, audited access	Sensitive personal data, keys, non-public financial information

Restricted-class data may only be stored in systems approved by the Security team and never on personal devices or non-corporate services.

3. Identity and access management

3.1 Passwords and authentication

Corporate passwords must be at least 14 characters long and are managed through the corporate password manager 1Password. Periodic rotation is not required except upon suspected compromise, in line with NIST 800-63B recommendations. Multi-factor authentication (MFA) is mandatory on all systems: TOTP is accepted for standard users, while production administrators must use YubiKey physical security keys.

Single sign-on (SSO) is centralized in Okta. Every new application must be integrated with Okta before its official adoption.

3.2 Access reviews

Access to systems containing Confidential or Restricted information is reviewed quarterly. Access to production infrastructure is granted under the principle of least privilege, with temporary (just-in-time) elevation of up to 8 hours through the internal approval system. Accounts are deactivated within 4 hours of an employee's departure.

3.3 Secrets management

Application credentials, tokens, and certificates are stored exclusively in HashiCorp Vault. Including secrets in source code, versioned environment variables, or shared documents is prohibited. Automatic secret scanning runs on every commit using Gitleaks.

4. Data protection

4.1 Encryption

All data at rest is encrypted with AES-256. Communications in transit use TLS 1.3 at minimum; TLS 1.2 is only temporarily allowed for legacy customer integrations and must be eliminated before December 2026. The disks of all corporate laptops have full-disk encryption (FileVault or BitLocker), verified by the MDM.

4.2 Backups

Production databases have a recovery point objective (RPO) of 1 hour and a recovery time objective (RTO) of 4 hours. Backups are retained for 35 days and replicated to a secondary region. Backup restoration is verified through a documented monthly test by the Platform team.

4.3 Log retention

Audit logs from production systems are retained for 400 days in immutable storage. Physical office access logs are kept for 90 days.

5. Device and network security

All corporate devices are enrolled in the Kandji MDM with automatic lock policies after 5 minutes of inactivity. Remote access to internal resources is performed exclusively through WireGuard VPN with per-device authentication. Personal devices (BYOD) are allowed only for email and Slack, provided the device has a screen lock and the corporate management app installed.

6. Security incident management

Any suspected incident must be reported immediately to the #security-incidents Slack channel or to security@nimbusdata.com. Incidents are classified and handled according to the following matrix:

Severity	Example	Max. first-response time
Critical (S1)	Confirmed customer data leak	30 minutes
High (S2)	Compromise of an internal account	2 hours
Medium (S3)	Malware contained on an endpoint	8 hours
Low (S4)	Reported phishing with no click	2 business days

Critical or High severity incidents require a post-incident report within 5 business days of closure and notification to affected customers according to the applicable contractual and regulatory deadlines (a maximum of 72 hours for personal data).

7. Awareness and testing

All staff complete a security training upon joining and every 6 months thereafter, including phishing simulations. The click rate in simulations during the second half of 2025 was 3.1%, below the internal target of 5%. An external penetration test is contracted annually; the 2025 edition was performed by the firm Carbide Security and produced no critical findings.

8. Compliance

Non-compliance with this policy may result in disciplinary action. Exceptions must be requested in writing to the CISO and are valid for a maximum of 90 days, renewable only once. This policy is reviewed every 12 months or upon significant changes in the threat landscape.